greenlight by Medivis

SOC 2 & HITRUST Certification Strategy & Roadmap

Technical Requirements, Implementation Timeline, Budget Estimates & Compliance Framework Mapping

12 mo	18 mo	90+	$250–500K
SOC 2 TYPE II CERTIFICATION	HITRUST R2 FULL ASSESSMENT	CONTROLS TO MAP & EVIDENCE	TOTAL 2-YEAR INVESTMENT

Prepared: March 2026

Classification: Confidential — Version 1.0

CONTENTS

Table of Contents

01	Executive Summary & Current State Assessment	03
02	SOC 2 Trust Services Criteria Mapping	04
03	HITRUST CSF Control Domain Mapping	05
04	Certification Pathway & Timeline	06
05	Technical Requirements — What to Build	07
06	Policy & Procedure Requirements	08
07	Vendor & Tool Requirements	09
08	Budget Estimates & Financial Planning	10
09	Risk Assessment Summary	11
10	Recommended Action Plan — Next 30/60/90 Days	12

How to read this document: This roadmap is designed for leadership, investors, and enterprise prospects. Sections 01–03 cover the current state and framework mappings. Sections 04–06 detail the technical and procedural work required. Sections 07–08 cover vendor selection and budgets. Sections 09–10 provide the risk assessment and immediate action plan.

70%	Sprint 13	~30%
TECHNICAL CONTROLS ALREADY IMPLEMENTED	SECURITY HARDENING COMPLETED	POLICY & PROCESS WORK REMAINING

SECTION 01

Executive Summary & Current State Assessment

GreenLight has invested heavily in security engineering from Sprint 13. The compliance gap is predominantly in policy documentation, process formalization, and third-party assessments — not in technical controls.

The GreenLight advantage: Most healthcare startups begin their SOC 2 journey at 0% technical control implementation. GreenLight has completed 70%+ of the technical security controls through Sprint 13's security hardening sprint. The remaining work is primarily organizational: writing policies, implementing endpoint management, conducting training, and engaging auditors. This dramatically compresses the timeline and reduces remediation costs.

What Exists vs. What Needs to Be Built

Implemented (Sprint 13 & Prior)

- ✓ AES-256-GCM encryption for PHI at rest
- ✓ HIPAA audit logging (all PHI access events)
- ✓ Role-based access control (RBAC)
- ✓ Rate limiting on all API endpoints
- ✓ Security headers (HSTS, CSP, X-Frame-Options)
- ✓ CI/CD pipeline with security scanning
- ✓ Incident response plan (initial draft)
- ✓ BAA checklist and tracking system
- ✓ Data flow diagram (PHI lifecycle)
- ✓ TLS 1.2+ transport encryption
- ✓ Input validation and sanitization
- ✓ Session management with secure tokens

Not Yet Built / Formalized

- ✗ Formal written security policies (13 required)
- ✗ Endpoint management / MDM solution
- ✗ Employee security awareness training
- ✗ Annual penetration testing
- ✗ Vendor risk assessment program
- ✗ Formal access review process (quarterly)
- ✗ Background check program
- ✗ Business continuity / disaster recovery testing
- ✗ Change management formal process
- ✗ MFA enforcement across all systems
- ✗ Vulnerability scanning (continuous)
- ✗ Risk management framework documentation

Control Implementation Readiness by Category

85%	75%	60%	15%
DATA ENCRYPTION & PROTECTION	ACCESS CONTROL & AUTHENTICATION	AUDIT LOGGING & MONITORING	POLICY & GOVERNANCE DOCUMENTATION

Strategic insight: The compliance landscape has shifted. Enterprise health systems and payers now require SOC 2 Type II as a *minimum* procurement gate, and HITRUST r2 as the gold standard. athenahealth requires HITRUST self-assessment within 90 days of marketplace GA. Starting the compliance program now ensures GreenLight is not blocked on enterprise sales when the EHR integrations are production-ready.

SECTION 02

SOC 2 Trust Services Criteria Mapping

SOC 2 evaluates controls across 5 Trust Services Criteria. GreenLight should certify against Security (CC), Availability (A1), and Confidentiality (C1) — the three categories most relevant to healthcare SaaS.

Security
CC1–CC9 • REQUIRED
COMMON CRITERIA

Availability
A1 • RECOMMENDED
UPTIME & RECOVERY

Confidentiality
C1 • RECOMMENDED
PHI PROTECTION

Security Common Criteria (CC1–CC9)

CRITERIA	CATEGORY	KEY CONTROLS	STATUS	EVIDENCE
CC1	Control Environment	Org structure, ethics, oversight, HR policies	Not started	Policies to be written
CC2	Communication & Information	Internal/external communication, reporting	Partial	Incident response draft exists
CC3	Risk Assessment	Risk identification, analysis, mitigation	Not started	Risk register needed
CC4	Monitoring Activities	Ongoing evaluation, deficiency remediation	Partial	CI/CD scanning, audit logs
CC5	Control Activities	Technical controls, change management	Implemented	RBAC, encryption, security headers
CC6	Logical & Physical Access	Access provisioning, authentication, MFA	Partial	RBAC done; MFA, access reviews needed
CC7	System Operations	Vulnerability mgmt, incident detection, response	Partial	Rate limiting, IRP draft; pen test needed
CC8	Change Management	Change authorization, testing, approval	Partial	CI/CD exists; formal process needed
CC9	Risk Mitigation	Vendor management, business continuity	Not started	Vendor risk program needed

Availability & Confidentiality Criteria

CRITERIA	CATEGORY	KEY CONTROLS	STATUS	EVIDENCE
A1.1	Capacity Management	Performance monitoring, capacity planning	Partial	Vercel auto-scaling; monitoring needed
A1.2	Recovery Operations	Backup, recovery testing, DR plan	Partial	Neon backups; DR testing needed
A1.3	Recovery Testing	Annual BCP/DR testing	Not started	DR plan and test needed
C1.1	Confidential Information	Data classification, encryption, access controls	Implemented	AES-256-GCM, RBAC, data flow diagram
C1.2	Disposal of Data	Data retention, secure disposal procedures	Not started	Retention policy needed

Summary: Of the 14 criteria areas above, 2 are fully implemented, 7 are partially implemented (technical controls exist but formal processes need documentation), and 5 require new work. The heaviest lift is CC1 (governance policies), CC3 (risk assessment), and CC9 (vendor management) — all organizational, not technical.

SECTION 03

HITRUST CSF Control Domain Mapping

HITRUST CSF v11 organizes controls into 14 domains. The e1 (essentials) assessment covers 44 core controls across these domains. GreenLight's Sprint 13 work provides significant coverage.

26	10	8	44
E1 CONTROLS IMPLEMENTED	E1 CONTROLS PARTIAL	E1 CONTROLS NOT STARTED	TOTAL E1 ESSENTIAL CONTROLS

ID	DOMAIN	E1 CTRLS	STATUS	GREENLIGHT COVERAGE	GAP / ACTION NEEDED
02	Information Protection Program	5	1 of 5	Incident response draft exists	Security program charter, risk assessment, policy suite
03	Endpoint Protection	3	0 of 3	No MDM deployed	Deploy endpoint management (Jamf/Kandji), anti-malware
04	Portable Media Security	2	2 of 2	Cloud-only architecture; no portable media in use	Document policy prohibiting portable media for PHI
05	Mobile Device Security	2	1 of 2	Web app only; no native mobile app	Mobile device policy needed
06	Wireless Security	2	1 of 2	TLS 1.2+ on all connections	Wireless security policy for remote workers
07	Configuration Management	4	3 of 4	CI/CD pipeline, infrastructure-as-code, security scanning	Formal change management process documentation
08	Vulnerability Management	3	1 of 3	CI/CD security scanning	Continuous vuln scanning, pen testing, remediation SLAs
09	Network Protection	3	2 of 3	Security headers, rate limiting, TLS	Network segmentation documentation
10	Transmission Protection	3	3 of 3	TLS 1.2+, AES-256-GCM, HSTS enforced	Fully covered
11	Password Management	3	2 of 3	Secure session tokens, password validation	Formal password policy + MFA enforcement
12	Access Control	5	3 of 5	RBAC, session management, input validation	Quarterly access reviews, least-privilege audit
13	Audit Logging & Monitoring	4	3 of 4	HIPAA audit logging, PHI access tracking	Log retention policy, alerting rules, SIEM integration
14	Education, Training & Awareness	3	0 of 3	No training program exists	Security awareness training platform, annual training
15	Third Party Assurance	2	0 of 2	BAA checklist exists but no vendor risk program	Vendor risk assessments, third-party security reviews

e1 vs. r2 strategy: The HITRUST e1 assessment (44 controls) is the fastest path to certification and sufficient for most initial enterprise sales. The r2 assessment adds risk-based controls (190+ total) and is the "gold standard" that large IDNs and national payers require. Recommendation: achieve e1 first (Month 9–12), then pursue r2 (Month 12–18) while revenue justifies the investment.

SECTION 04

Certification Pathway & Timeline

A parallel-track approach targeting SOC 2 Type II in 9–12 months and HITRUST r2 in 18 months. The observation periods overlap to maximize velocity.

Months 1–2: Foundation & Setup

- Select and deploy compliance platform (Vanta/Drata/Secureframe)
- Write core security policies (Information Security, Access Control, Change Mgmt)
- Begin automated evidence collection
- Engage SOC 2 audit firm and HITRUST assessor
- Deploy endpoint management solution

Milestone: Compliance platform live, 5+ policies approved

Months 2–3: Gap Remediation

- Deploy MFA enforcement across all systems
- Complete employee security awareness training
- Schedule and execute first penetration test
- Implement continuous vulnerability scanning
- Conduct formal risk assessment
- Establish vendor risk assessment program

Milestone: All critical gaps remediated

Month 3: SOC 2 Type I Audit

- Point-in-time assessment of control design
- Auditor evaluates all documented controls
- Produces Type I report (design effectiveness)
- Identifies any remaining remediation items

Milestone: SOC 2 Type I report issued

Months 3–9: SOC 2 Type II Observation

- 6-month observation period begins
- Continuous evidence collection via compliance platform
- Quarterly access reviews executed
- Ongoing vulnerability scanning and remediation
- Incident response tabletop exercises

Milestone: Observation period complete

Months 6–9: HITRUST e1 Self-Assessment

- Map 44 essential controls to evidence
- Complete HITRUST MyCSF portal entries
- Internal readiness review
- Submit for HITRUST e1 validated assessment

Milestone: HITRUST e1 assessment submitted

Months 9–12: Certifications Issued

- Month 9: SOC 2 Type II report issued
- Month 9–12: HITRUST e1 certification issued
- Begin HITRUST r2 scoping (190+ controls)

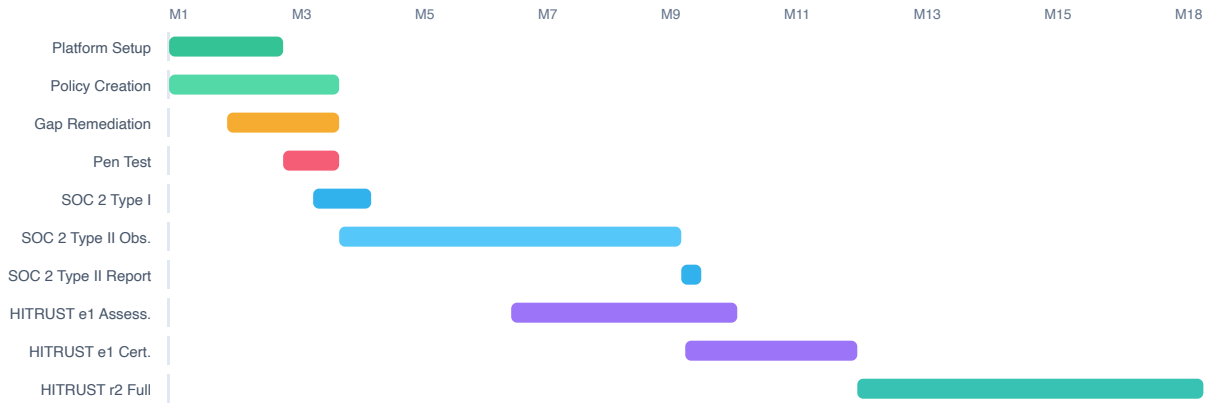
Milestone: SOC 2 Type II + HITRUST e1 certified

Months 12–18: HITRUST r2 Full Assessment

- Complete risk-based control implementation
- Engage authorized external assessor
- Full r2 assessment and HITRUST QA review
- HITRUST r2 certification issued

Milestone: HITRUST r2 — gold standard achieved

Certification Timeline Gantt Chart



SECTION 05

Technical Requirements — What to Build

Remaining technical work to close compliance gaps. Organized by priority and effort. Most items are configuration/deployment rather than new application code.

P0: MFA Enforcement

Enforce multi-factor authentication across all systems: production infrastructure, source code (GitHub), compliance platform, cloud consoles (Vercel, Neon). Use Azure AD / Entra ID or Okta as identity provider.

Effort: 1–2 days • **Blocks:** SOC 2 CC6, HITRUST 11, 12

Critical | Week 1

P1: Database Audit Logging Enhancement

Enable comprehensive database audit logging on Neon PostgreSQL. Track all DDL changes, privileged operations, and schema modifications. Ensure log retention meets SOC 2 requirements (minimum 1 year).

Effort: 1–2 days • **Blocks:** SOC 2 CC4, HITRUST 13

Medium | Week 3–4

P0: Endpoint Management (MDM)

Deploy MDM solution (Jamf for macOS, Kandji, or Microsoft Intune) on all developer and employee devices. Enforce disk encryption, screen lock, OS patching, and remote wipe capability.

Effort: 1–2 weeks • **Blocks:** HITRUST 03, 05

Critical | Week 1–2

P1: Backup Verification Testing

Implement automated backup restoration testing. Verify Neon database backups can be restored to a point-in-time. Document RPO (Recovery Point Objective) and RTO (Recovery Time Objective). Run monthly.

Effort: 2–3 days • **Blocks:** SOC 2 A1, HITRUST 07

Medium | Week 3–4

P1: Continuous Vulnerability Scanning

Implement automated vulnerability scanning beyond CI/CD. Options: Qualys, Tenable, or Snyk for application-level scanning. Run scheduled scans weekly with automated ticket creation for findings.

Effort: 2–3 days • **Blocks:** SOC 2 CC7, HITRUST 08

High | Week 2–3

P2: Container & Dependency Scanning in CI/CD

Add container image scanning (Trivy or Snyk Container) to the existing CI/CD pipeline. Scan for known CVEs in base images and dependencies. Block deployments with critical/high findings.

Effort: 1 day • **Blocks:** SOC 2 CC8, HITRUST 07, 08

Enhancement | Week 4–6

P1: Monitoring & Alerting Rules

Configure alert rules for security events: failed login attempts (>5 in 10 min), unauthorized PHI access attempts, bulk data export, elevated privilege usage, after-hours access patterns. Route to PagerDuty or Opsgenie.

Effort: 3–5 days • **Blocks:** SOC 2 CC4, CC7, HITRUST 13

High | Week 2–4

P2: Network Segmentation Review

Document and verify network segmentation between application tiers. Ensure database is not directly accessible from the internet. Review Vercel/Neon network isolation. Document firewall rules and access paths.

Effort: 1–2 days • **Blocks:** SOC 2 CC6, HITRUST 09

Enhancement | Week 4–6

Total estimated technical effort: 4–6 weeks of engineering time, much of it parallelizable. The largest items (MDM deployment, vulnerability scanning, monitoring rules) are configuration work, not new application development. No changes to the GreenLight core application codebase are required — these are infrastructure and tooling items.

SECTION 06

Policy & Procedure Requirements

SOC 2 and HITRUST require formal, board-approved written policies. Compliance platforms (Vanta, Drata, Secureframe) provide templates that reduce writing time from weeks to days per policy.

POLICY	SOC 2	HITRUST	OWNER	EST. TIME	TEMPLATE	KEY CONTENTS
Information Security Policy	CC1	02	CISO / CTO	2–3 days	Yes	Security program charter, objectives, scope, roles
Acceptable Use Policy	CC1, CC6	02, 12	CTO	1–2 days	Yes	Permitted system use, prohibited activities, monitoring
Data Classification Policy	C1	02, 04	CTO	1–2 days	Yes	PHI, PII, confidential, internal, public classifications
Access Control Policy	CC6	11, 12	CTO	2–3 days	Yes	Least privilege, provisioning, deprovisioning, reviews
Change Management Policy	CC8	07	CTO	2–3 days	Yes	Change request, approval, testing, rollback procedures
Incident Response Policy	CC2, CC7	02, 13	CTO	1 day	Draft exists	Detection, containment, eradication, recovery, lessons
Business Continuity / DR Policy	A1	02, 07	CTO	2–3 days	Yes	RPO/RTO targets, failover, backup, testing schedule
Vendor Management Policy	CC9	15	CTO / Ops	2–3 days	Yes	Vendor assessment, risk scoring, annual reviews, BAAs
Data Retention & Disposal Policy	C1	02, 04	CTO	1–2 days	Yes	Retention periods, disposal methods, crypto-shredding
Employee Security Policy	CC1	14	HR / CTO	1–2 days	Yes	Background checks, onboarding, offboarding, training
Physical Security Policy	CC6	02	CTO / Ops	1 day	Yes	Remote work security, home office, visitor policy
Risk Management Policy	CC3	02	CTO	2–3 days	Yes	Risk identification, assessment, treatment, register
Privacy Policy (HIPAA NPP)	P1	02	Legal / CTO	3–5 days	Partial	Notice of Privacy Practices, patient rights, uses/disclosures

13
POLICIES REQUIRED

4–6 wk
TOTAL WRITING TIMELINE

Compliance platform advantage: Vanta, Drata, and Secureframe all provide pre-written, attorney-reviewed policy templates customized for healthcare SaaS companies. Using templates reduces per-policy writing time from 1–2 weeks to 1–3 days. Templates cover 11 of 13 required policies. Budget 4–6 weeks total for the complete policy suite.

Critical requirement: Policies must be formally approved by leadership (CEO/CTO sign-off), distributed to all employees, and acknowledged in writing. Annual policy reviews are required. The compliance platform automates distribution, acknowledgment tracking, and review scheduling. Without this evidence, the SOC 2 auditor will issue a finding.

SECTION 07

Vendor & Tool Requirements

The compliance toolchain required to achieve and maintain SOC 2 Type II and HITRUST certifications. Organized by priority and annual cost.

TOOL / VENDOR	PURPOSE	ANNUAL COST	PRIORITY	RECOMMENDED OPTIONS & NOTES
Compliance Platform	Automated evidence collection, policy management, audit readiness	$10–25K/yr	P0	**Vanta** (best HITRUST support), **Drata** (best UI), or **Secureframe** (best for startups). All support SOC 2 + HITRUST. Vanta recommended for dual-certification path.
SOC 2 Audit Firm	Independent Type I + Type II audit	$15–30K/yr	P0	**Prescient Assurance**, **Johanson Group**, **Schellman**, or **A-LIGN**. Choose a firm experienced with healthcare SaaS. Many compliance platforms have preferred auditor partnerships with discounted rates.
Penetration Testing	Annual security assessment	$5–15K/test	P0	**Cobalt** (pentest-as-a-service), **Synack**, or **HackerOne**. Minimum annual; quarterly recommended. Must include web app, API, and infrastructure testing.
Endpoint Management	MDM, disk encryption, patching	$5–10/device/mo	P0	**Jamf** (macOS-focused), **Kandji** (modern macOS), or **Microsoft Intune** (cross-platform). Jamf if all-Mac team; Intune if mixed OS. Integrates with compliance platform.
Security Training	Employee awareness, phishing simulation	$2–5K/yr	P1	**KnowBe4** (most comprehensive), **Curricula** (startup-friendly), or **Hoxhunt**. Annual training + quarterly phishing simulations. Most compliance platforms include basic training modules.
Background Checks	Pre-employment screening	$30–50/employee	P1	**Checkr** or **GoodHire**. Required for all employees with PHI access. Criminal, education, and employment verification. Run at hire and annual re-check for sensitive roles.
Cyber Liability Insurance	Breach coverage, regulatory defense	$3–10K/yr	P1	**Coalition**, **Cowbell**, or **At-Bay**. Required by most enterprise customers in procurement. $1–5M coverage typical. SOC 2 certification reduces premiums 10–30%.
HITRUST Ext. Assessor	Authorized assessor for r2	$30–50K	P2	**Coalfire**, **Schellman**, **A-LIGN**, or **LBMC**. Must be HITRUST-authorized. Required for r2 validated assessment. e1 can be done without external assessor if using compliance platform.
SIEM (Optional)	Centralized log management, threat detection	Usage-based	P2	**Datadog Security**, **Elastic SIEM**, or **Panther**. Not strictly required for SOC 2 Type II but strengthens CC7 posture. Consider when processing volume warrants investment.

Recommended Vendor Stack

Optimal Stack (Best-in-Class)

Compliance: Vanta ($15K/yr) • **Audit:** Prescient Assurance ($20K) • **Pen Test:** Cobalt ($8K) • **MDM:** Kandji ($8/dev/mo) • **Training:** Curricula ($3K/yr) • **Insurance:** Coalition ($5K/yr)

Year 1 total: ~$60K

Budget Stack (Startup-Friendly)

Compliance: Secureframe ($10K/yr) • **Audit:** Johanson Group ($15K) • **Pen Test:** Cobalt ($5K) • **MDM:** Mosyle ($4/dev/mo) • **Training:** Platform-included • **Insurance:** At-Bay ($3K/yr)

Year 1 total: ~$38K

Vendor consolidation note: Many compliance platforms bundle security training, policy templates, vendor risk assessments, and evidence collection into a single platform. Vanta's HITRUST module automates MyCSF data entry and maps SOC 2 evidence directly to HITRUST controls — reducing duplicate work by 50–70% when pursuing both certifications.

SECTION 08

Budget Estimates & Financial Planning

Total estimated 2-year investment for SOC 2 Type II + HITRUST r2 certifications: $250K–$500K. This includes all tooling, assessments, and personnel costs.

$115–215K	$135–285K	$75–150K	$250–500K
YEAR 1 COSTS SOC 2 + HITRUST E1	YEAR 2 COSTS HITRUST R2 + RENEWALS	ANNUAL ONGOING MAINTENANCE	TOTAL 2-YEAR INVESTMENT

Year 1: SOC 2 Type I + Type II + HITRUST e1

CATEGORY	ITEM	LOW ESTIMATE	HIGH ESTIMATE	NOTES
Platform	Compliance platform (Vanta/Drata)	$10K	$25K	Annual license; includes policy templates
Audit	SOC 2 Type I + Type II audit	$15K	$30K	Single firm for both; bundled pricing
Audit	HITRUST e1 assessment fees	$15K	$30K	MyCSF license + validated assessment
Tools	Endpoint management (MDM)	$3K	$8K	$5–10/device/month; 5–15 devices
Tools	Vulnerability scanning	$3K	$8K	Snyk, Qualys, or Tenable
Pen Test	Penetration testing (1–2 tests)	$5K	$15K	Web app + API + infrastructure
Personnel	Part-time compliance lead	$30K	$50K	Contractor or fractional CISO; 6–12 months
Training	Security awareness + phishing	$2K	$5K	Annual training for all employees
Legal	Policy review + HIPAA counsel	$10K	$20K	Attorney review of policies and BAAs
Insurance	Cyber liability insurance	$3K	$10K	$1–5M coverage
Background	Employee background checks	$500	$2K	$30–50 per employee
Misc	Monitoring / alerting tools	$3K	$8K	PagerDuty, Datadog, or similar
Year 1 Total		**$99.5K**	**$211K**	

Year 2: HITRUST r2 + Renewals

CATEGORY	ITEM	LOW ESTIMATE	HIGH ESTIMATE	NOTES
Audit	HITRUST r2 external assessor	$30K	$50K	Authorized external assessor required
Audit	HITRUST r2 assessment fees	$25K	$50K	MyCSF license + QA review
Audit	SOC 2 Type II renewal	$12K	$25K	Annual renewal audit
Platform	Compliance platform renewal	$10K	$25K	Annual license
Pen Test	Penetration testing (annual)	$5K	$15K	Annual requirement

SECTION 09

Risk Assessment Summary

Top 10 compliance and security risks for GreenLight, with likelihood, impact, current mitigations, and recommended additional controls. This assessment informs the SOC 2 CC3 risk register.

#	RISK	LIKELIHOOD	IMPACT	CURRENT MITIGATION	RECOMMENDED ADDITIONAL CONTROLS
1	PHI breach via cloud misconfiguration	Medium	Critical	AES-256-GCM encryption, TLS 1.2+, security headers	Cloud security posture management (CSPM), automated config drift detection, quarterly cloud security review
2	Unauthorized access via credential compromise	Medium	Critical	RBAC, session management, rate limiting	MFA enforcement (P0), SSO integration, credential rotation policy, impossible travel detection
3	Third-party vendor data breach	Medium	High	BAA checklist exists	Vendor risk assessment program, annual vendor security reviews, vendor SOC 2 report collection
4	Employee device compromise	Medium	High	None (no MDM)	Deploy MDM (P0), enforce disk encryption, remote wipe capability, OS patching enforcement
5	Audit logging gaps — undetected PHI access	Low	High	HIPAA audit logging for PHI events	SIEM integration, log integrity monitoring, alerting rules for anomalous access patterns
6	Delayed breach notification (>60 days HIPAA)	Low	Critical	Incident response plan (draft)	Formalize IRP, conduct tabletop exercises, define escalation matrix, automate notification workflows
7	Inadequate backup / recovery failure	Low	High	Neon automated backups	Monthly backup restore testing, documented RPO/RTO, geographic redundancy, DR runbook
8	Social engineering / phishing attacks	Medium	Medium	None (no training program)	Security awareness training (P1), quarterly phishing simulations, email security (DMARC/DKIM)
9	Regulatory changes (CMS, state privacy laws)	Medium	Medium	CMS-0057-F tracking	Regulatory monitoring service, legal counsel on retainer, quarterly compliance review meetings
10	API / FHIR endpoint exploitation	Low	High	Rate limiting, input validation, CSP headers	API security gateway, FHIR-specific penetration testing, OAuth scope enforcement review

Risk Heatmap Summary

3 CRITICAL RISKS (IMMEDIATE ACTION)

4 HIGH RISKS (30-DAY ACTION)

3 MEDIUM RISKS (60-DAY ACTION)

Top priority: Risks #1–#4 are the highest combined likelihood + impact. MFA enforcement and endpoint management (both P0 items from Section 05) directly mitigate risks #2 and #4. The vendor risk assessment program addresses risk #3. These three actions eliminate or significantly reduce 4 of the top 5 risks.

Risk register maintenance: This assessment should be reviewed quarterly and updated as controls are implemented. The compliance platform maintains a living risk register that maps directly to SOC 2 CC3 and HITRUST 02 evidence requirements. Each risk should have an assigned owner, a target remediation date, and a residual risk rating after controls are applied.

SECTION 10

Recommended Action Plan — Next 30/60/90 Days

Concrete, time-bound action items to initiate the compliance program. Each item has an owner, estimated effort, and the certification requirement it satisfies.

Days 1–30: Foundation Sprint

- **Sign compliance platform contract** (Vanta recommended) — enables automated evidence collection from day 1
- **Write 5 core policies:** Information Security, Access Control, Change Management, Acceptable Use, Data Classification
- **Deploy endpoint management** (Kandji/Jamf) on all team devices — closes HITRUST 03 gap
- **Enforce MFA** across GitHub, Vercel, Neon, and all cloud consoles
- **Schedule penetration test** for Day 45–60 window
- **Engage SOC 2 audit firm** — begin readiness assessment
- **Initiate background checks** for all current employees

Deliverable: Compliance platform live, 5 policies approved, MDM deployed, MFA enforced

Days 31–60: Remediation Sprint

- **Complete remaining 8 policies:** Incident Response (finalize), BCP/DR, Vendor Management, Data Retention, Employee Security, Physical Security, Risk Management, Privacy
- **Execute penetration test** and remediate critical/high findings
- **Deploy continuous vulnerability scanning** (Snyk or Qualys)
- **Launch employee security training** for all team members
- **Conduct formal risk assessment** and populate risk register
- **Begin SOC 2 Type I readiness assessment** with audit firm
- **Obtain cyber liability insurance** policy

Deliverable: All 13 policies approved, pen test complete, training complete, risk register live

Days 61–90: Audit Launch Sprint

- **SOC 2 Type I audit begins** — point-in-time control assessment
- **Begin SOC 2 Type II observation period** (6 months) immediately after Type I
- **Start HITRUST e1 self-assessment** in MyCSF portal
- **Execute all outstanding BAAs** (Vercel Enterprise, Neon HIPAA tier, any new vendors)
- **Implement quarterly access review process** — first review in this window
- **Configure monitoring and alerting rules** (failed logins, PHI export, privilege escalation)
- **Conduct first backup restoration test** and document RPO/RTO
- **Begin vendor risk assessments** for all critical vendors

Deliverable: SOC 2 Type I report, Type II observation active, HITRUST e1 scoping complete

Parallel execution with EHR integration: Compliance work runs alongside the EHR integration sprints — they do not block each other. SMART on FHIR, Da Vinci CRD, DTR, and PAS development continues uninterrupted. The compliance platform automates most evidence collection from the existing CI/CD pipeline and production infrastructure. Engineering time commitment for compliance: ~10–15% of one engineer's time.

After 90 days, GreenLight will have: a SOC 2 Type I report (usable for enterprise sales immediately), an active Type II observation period, all required policies in place, endpoint management deployed, MFA enforced, pen test completed, and the HITRUST e1 assessment underway. This positions GreenLight as compliance-ready for Epic, athenahealth, and enterprise health system procurement processes.

Day 1	Day 90	Month 9	Month 18
SIGN COMPLIANCE PLATFORM	SOC 2 TYPE I REPORT ISSUED	SOC 2 TYPE II REPORT ISSUED	HITRUST R2 CERTIFIED